change this to read `user=admin` by simple manipulation of the ciphertext even though you can't decrypt the token. Although there isn't room to go into the details here, this kind of attack is often covered in basic cryptography tutorials and is easy to carry out.

In terms of threat models from chapter 1, encryption protects against information disclosure threats, but not against spoofing or tampering. In some cases, confidentiality can also be lost if there is no guarantee of integrity because an attacker can alter a message and then see what error message is generated when the API tries to decrypt it. This often leaks information about what the message decrypted to.

> **LEARN MORE** You can learn more about how modern encryption algorithms work, and attacks against them, from an up to date introduction to cryptography book such as *Serious Cryptography* by Jean-Philippe Aumasson (NoStarch, 2018).

To protect against spoofing and tampering threats, you should always use algorithms that provide *authenticated encryption*. Authenticated encryption algorithms combine an encryption algorithm for hiding sensitive data with a MAC algorithm, such as HMAC, to ensure that the data can't be altered or faked.

> **DEFINITION** ***Authenticated encryption*** combines an encryption algorithm with a MAC. Authenticated encryption ensures confidentiality and integrity of messages.